

Week 7 - Security Audit, Network Testing, and System Evaluation

The purpose of Week 7 was to conduct a full security audit of the Ubuntu server and evaluate the effectiveness of all previous hardening measures. This included:

- Performing a Lynis security scan
- Remediating weaknesses and rescanning
- Testing network exposure using Nmap
- Auditing SSH security
- Reviewing running services
- Identifying remaining risks

This stage validates whether the system meets secure configuration standards and highlights areas requiring further action.

Lynis is a professional security auditing tool used to assess system vulnerabilities:

```
Lynis security scan details:
Hardening index : 60 [#####          ]
Tests performed : 262
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status  [?]
- Security audit     [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

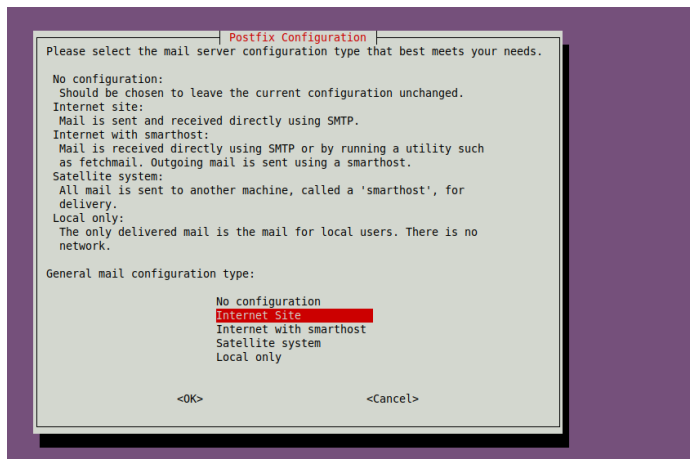
=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)
```

```
- [ Lynis 3.0.9 Results ] -

Warnings (1):
-----
! Found one or more vulnerable packages. [PKGS-7392]
https://cisofy.com/lynis/controls/PKGS-7392/
```

I then installed necessary dependencies to improve the VM:



```
katana@katana-VirtualBox:~$ sudo apt install rkhunter
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  bsd-mailx fonts-lato javascript-common libjs-jquery liblockfile-bin liblockfile1 libnsl2 libruby libruby3.2 postfix rake ruby ruby-net-telnet
  ruby-rubygems ruby-sdbm ruby-webrick ruby-xmlrpc ruby3.2 rubygems-integration unhide unhide.rb
Suggested packages:
  apache2 | lighttpd | httpd postfix-cdb postfix-doc postfix-ldap postfix-lmdb postfix-mta-sts-resolver postfix-mysql postfix-pcre postfix-pgsql
  postfix-sqlite procmail sasl2-bin | dovecot-common ri ruby-dev bundler
The following NEW packages will be installed:
  bsd-mailx fonts-lato javascript-common libjs-jquery liblockfile-bin liblockfile1 libnsl2 libruby libruby3.2 postfix rake rkhunter ruby ruby-net-telnet
  ruby-rubygems ruby-sdbm ruby-webrick ruby-xmlrpc ruby3.2 rubygems-integration unhide unhide.rb
0 to upgrade, 22 to newly install, 0 to remove and 31 not to upgrade.
Need to get 10.6 MB of archives.
After this operation, 47.0 MB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://archive.ubuntu.com/ubuntu noble/main amd64 fonts-lato all 2.015-1 [2,781 kB]
Get:2 http://archive.ubuntu.com/ubuntu noble/main amd64 libnsl2 amd64 1.3.0-3build3 [41.4 kB]
Get:3 http://archive.ubuntu.com/ubuntu noble/main amd64 postfix amd64 3.8.6-1build2 [1,254 kB]
Get:4 http://archive.ubuntu.com/ubuntu noble/universe amd64 rkhunter all 1.4.6-12 [219 kB]
Get:5 http://archive.ubuntu.com/ubuntu noble/main amd64 liblockfile-bin amd64 1.17-1build3 [11.2 kB]
Get:6 http://archive.ubuntu.com/ubuntu noble/main amd64 liblockfile1 amd64 1.17-1build3 [6,840 B]
Get:7 http://archive.ubuntu.com/ubuntu noble/main amd64 bsd-mailx amd64 8.1.2-0.20220412cvs-1build1 [67.2 kB]
Get:8 http://archive.ubuntu.com/ubuntu noble/main amd64 javascript-common all 11+nmu1 [5,936 B]
Get:9 http://archive.ubuntu.com/ubuntu noble/main amd64 libjs-jquery all 3.6.1+dfsg+~3.5.14-1 [328 kB]
```

I disabled password authentication:

```
# Example of overriding settings on a per-user basis
#Match User anoncvs
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server
AllowUsers vboxuser studentuser
PasswordAuthentication no
```

I also disabled unnecessary services:

```
katana@katana-VirtualBox:~$ sudo systemctl disable bluetooth.service
Synchronizing state of bluetooth.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install disable bluetooth
katana@katana-VirtualBox:~$ sudo systemctl stop bluetooth.service
katana@katana-VirtualBox:~$
```

I improved firewall logging:

```
katana@katana-VirtualBox:~$ sudo ufw logging on
Logging enabled
katana@katana-VirtualBox:~$
```

I then ran a second audit test to see if the changes helped:

```
Lynis security scan details:
Hardening index : 61 [##### ]
Tests performed : 262
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [V]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)

katana@katana-VirtualBox:~$
```

There has been slight improvement in the results for the system audit.

I tested the network security using Nmap. These were the results:

```
katana@katana-VirtualBox:~$ nmap -sV -p- 192.168.56.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-14 20:21 GMT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.11 seconds
katana@katana-VirtualBox:~$ nmap -Pn -sV -p- 192.168.56.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-14 20:31 GMT
Nmap scan report for 192.168.56.10
Host is up (0.11s latency).
All 65535 scanned ports on 192.168.56.10 are in ignored states.
Not shown: 65525 filtered tcp ports (no-response), 10 filtered tcp ports (host-unreach)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 247.66 seconds
katana@katana-VirtualBox:~$
```

I then logged in to the SSH with the key:

```
katana@katana-VirtualBox:~$ ssh vboxuser@192.168.56.10
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-49-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

488 updates can be applied immediately.
238 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Last login: Fri Dec 12 19:20:13 2025 from 192.168.56.11
vboxuser@Ubuntu:~$
```

Service Inventory & Justification:

```

katana@katana-VirtualBox:~$ systemctl --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
avahi-daemon.service               loaded active running Avahi mDNS/DNS-SD Stack
colord.service                     loaded active running Manage, Install and Generate Color Profiles
cron.service                       loaded active running Regular background program processing daemon
cups-browsed.service               loaded active running Make remote CUPS printers available locally
cups.service                       loaded active running CUPS Scheduler
dbus.service                       loaded active running D-Bus System Message Bus
getty@tty1.service                 loaded active running Getty on tty1
irqbalance.service                loaded active running irqbalance daemon
kerneloops.service                loaded active running Tool to automatically collect and submit kernel crash signatures
lightdm.service                    loaded active running Light Display Manager
ModemManager.service              loaded active running Modem Manager
NetworkManager.service            loaded active running Network Manager
polkit.service                     loaded active running Authorization Manager
power-profiles-daemon.service        loaded active running Power Profiles daemon
rsyslog.service                   loaded active running System Logging Service
rtkit-daemon.service              loaded active running RealtimeKit Scheduling Policy Service
ssh.service                        loaded active running OpenSSH Secure Shell server
switcheroo-control.service          loaded active running Switcheroo Control Proxy service
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running User Login Management
systemd-resolved.service            loaded active running Network Name Resolution
systemd-timesyncd.service           loaded active running Network Time Synchronization
systemd-udev.service               loaded active running Rule-based Manager for Device Events and Files
udisks2.service                    loaded active running Disk Manager
upower.service                     loaded active running Daemon for power management
user@1000.service                  loaded active running User Manager for UID 1000
wpa_supplicant.service              loaded active running WPA supplicant

legend: LOAD    - Reflects whether the unit definition was properly loaded.
          ACTIVE - The high-level unit activation state, i.e. generalization of SUB.
          SUB    - The low-level unit activation state, values depend on unit type.

28 loaded units listed.
katana@katana-VirtualBox:~$

```

Fail2ban is an intrusion-prevention framework that monitors log files and automatically bans IP addresses that exhibit suspicious or malicious behaviour, such as repeated failed SSH login attempts. It adds an additional layer of security on top of SSH and UFW.

```

katana@katana-VirtualBox:~$ sudo systemctl enable fail2ban
Synchronizing state of fail2ban.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable fail2ban
katana@katana-VirtualBox:~$ sudo systemctl start fail2ban
katana@katana-VirtualBox:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
   Active: active (running) since Sun 2025-12-14 22:51:51 GMT; 1min 5s ago
     Docs: man:fail2ban(1)
    Main PID: 182530 (fail2ban-server)
      Tasks: 5 (limit: 2255)
    Memory: 23.3M (peak: 23.8M)
       CPU: 520ms
    CGroup: /system.slice/fail2ban.service
            └─182530 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Dec 14 22:51:51 katana-VirtualBox systemd[1]: Started fail2ban.service - Fail2Ban Service.
Dec 14 22:51:51 katana-VirtualBox fail2ban-server[182530]: 2025-12-14 22:51:51,686 fail2ban.configreader [182530]: WARNING 'allowipv6' not defined in 'Def
Dec 14 22:51:51 katana-VirtualBox fail2ban-server[182530]: Server ready
lines 1-14/14 (END)

```

I created a local jail configuration:

```

GNU nano 7.2 /etc/fail2ban/jail.local *
[sshd]
enabled = true
port = ssh
logpath = /var/log/auth.log
maxretry = 3
bantime = 600
findtime = 600

```

This means:

- 3 failed login attempts
- Within 10 mins
- Results in 10 min ban

```

katana@katana-VirtualBox:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 0
| - Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
- Actions
  |- Currently banned: 0
  |- Total banned: 0
  - Banned IP list:
katana@katana-VirtualBox:~$

```

This shows the number of failed attempts; banned IPS and jail status

I will intentionally login with incorrect information to see what occurs:

The results were that the Mint IP was banned after the repeated attempts

Week 7 required me to complete 2 Lynis scans; implement multiple remediation steps; verified network exposure with Nmap. I then confirmed SSH key-only authentication; audited system services; and identified remaining risks